COMPTIA SECURITY+ SY0-701 DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

# Security+ 3.2 · Network Appliances

Mestre CyberSec · **Aula 3.2 — Network Appliances** (11:56) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

**Resumo Executivo da Aula:** Appliances: jump server (única entrada pra admin); proxy (intermedia HTTP — cache/filter/auth); load balancer (distribui); sensors (IDS/IPS); collectors (junta logs pra SIEM).

## 💡 Highlights que a prova CompTIA cobra

- Jump box: única porta de ADMINISTRACAO — reduz surface
- Proxy: cache + filter + auth no tráfego HTTP
- Load balancer: distribui e dá redundância

## 🎯 Dicas de Prova & Cenários Típicos da Banca

- 'single entry point for administrators' = jump server

## 🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.2 — Network Appliances)

**Por que este aprofundamento é cobrado na prova?:** O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

**• Servidor de salto (Jump box) (N/A)**

Servidor endurecido e isolado que atua como ponto único de entrada administrativa para gerenciar sistemas críticos; administradores conectam-se a ele primeiro e depois acessam outros dispositivos.

⚠ ***Armadilha CompTIA:*** *Palavra-chave: 'single entry point for administrators' = jump server. Não confunda com proxy ou VPN; o foco é acesso administrativo controlado e auditado.*

**• Servidor Proxy (N/A)**

Aplicação intermediária que trata requisições de clientes, geralmente HTTP/HTTPS, oferecendo cache, filtragem de conteúdo, autenticação e logs.

⚠ ***Armadilha CompTIA:*** *Se a questão mencionar cache, filtro de URL/conteúdo e autenticação no tráfego web, pense em proxy. Forward proxy = atende clientes internos; reverse proxy = protege servidores internos.*

**• Proxy Direto (Forward Proxy) (N/A)**

Proxy posicionado entre usuários internos e redes externas, encaminhando requisições de saída dos clientes para a Internet e aplicando políticas.

⚠ ***Armadilha CompTIA:*** *Exam trigger: internal users accessing external sites through a proxy. It hides client IPs and filters outbound traffic. Not the same as reverse proxy.*

**• Proxy Reverso (N/A)**

Proxy colocado à frente de servidores internos para aceitar requisições de clientes externos, oferecendo balanceamento de carga, cache, terminação TLS e proteção.

⚠ ***Armadilha CompTIA:*** *Exam trigger: external clients accessing internal web servers; reverse proxy hides servers and can offload TLS/SSL. Contrast with forward proxy.*

**• Balanceador de Carga (LB)**

Dispositivo de rede que distribui o tráfego de entrada entre vários servidores para melhorar desempenho, disponibilidade e redundância.

⚠ ***Armadilha CompTIA:*** *Se a questão citar distribuição de tráfego, failover, health checks ou alta disponibilidade, escolha load balancer. Pode ser L4 (TCP/UDP) ou L7 (HTTP).*

**• Sensores (IDS/IPS)**

Sensores de rede monitoram tráfego em busca de atividade maliciosa; IDS detecta e alerta, enquanto IPS pode bloquear ou prevenir intrusões ativamente.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'detecta e alerta' = IDS; 'detecta e bloqueia' = IPS. Sensor é o componente que coleta/monitora o tráfego para o IDS/IPS.*

---

**• Coletor (N/A)**

Coletor de logs agrega e encaminha dados de log de várias fontes para um sistema central, geralmente um SIEM, para correlação e análise.

⚠️ ***Armadilha CompTIA:*** *Exam trigger: 'aggregates logs' or 'feeds SIEM' = collector. It does not analyze by itself; it centralizes/forwards logs.*

---

**• Gerenciamento de Informações e Eventos de Segurança (SIEM)**

Plataforma centralizada que coleta, correlaciona e analisa logs e eventos de segurança de múltiplas fontes para apoiar detecção e resposta.

⚠️ ***Armadilha CompTIA:*** *Se a questão falar em correlação de logs, dashboards, alertas centralizados e retenção para investigação, pense em SIEM. Collectors alimentam o SIEM.*

## 🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

### 📌 Módulo de Segurança em Hardware (HSM - Hardware Security Module)

🏠 **Analogia Intuitiva:** É um cofre de titânio suíço com blindagem anti-arrombamento instalada no rack do data center: as chaves criptográficas mestras são geradas e trancadas lá dentro e NUNCA saem para a memória do servidor nem para o disco. Se alguém tentar abrir a tampa do cofre com uma chave de fenda, um circuito interno detecta a vibração, queima os chips de memória e destrói as chaves imediatamente (Zeroization).

🔍 **Causa Raiz / Por que foi criado:** Servidores operacionais comuns armazenam chaves criptográficas na memória RAM ou em arquivos no disco, onde podem ser roubadas por malwares, despejos de memória (memory dumps) ou invasores com acesso root. O HSM isola o ciclo de vida criptográfico em hardware certificado (FIPS 140-2/3 Nível 3 ou 4).

🛡️ **Visão do Auditor de GRC:** Verificar se as chaves de Autoridade Certificadora Raiz (Root CA), chaves de assinatura de pagamentos (PCI-DSS) e criptografia mestre de banco de dados estão custodiadas em HSMs com certificação FIPS; auditar procedimento de cerimônia de chaves (Key Ceremony).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'dedicated physical hardware appliance certified to securely generate, store, and manage cryptographic keys with tamper-evident zeroization'. Resposta: HSM (Hardware Security Module).

### 📌 SIEM vs. SOAR: O Cérebro Analítico vs. O Robô de Resposta Automática

🏠 **Analogia Intuitiva:** O SIEM é o grande telão da torre de controle: ele coleta registros de 1.000 câmeras e sensores, cruza os horários e acende uma luz amarela dizendo: 'Atenção, o funcionário João logou no RH em São Paulo e 2 minutos depois logou em Londres' (agregação e correlação de logs). O SOAR é o robô de resgate automatizado: no mesmo segundo em que a luz amarela acende, o robô roda um script predefinido (Playbook), bloqueia o usuário João no Active Directory, encerra as sessões ativas e avisa o plantonista no Telegram.

🔍 **Causa Raiz / Por que foi criado:** O SIEM resolve a necessidade de centralizar terabytes de logs desconexos e correlacionar eventos de segurança. O SOAR resolve o gargalo humano: analistas não conseguem responder manualmente a milhares de alertas por segundo, então o SOAR orquestra ferramentas e automatiza a resposta.

🛡️ **Visão do Auditor de GRC:** Inspecionar fontes de logs enviadas ao SIEM e conferir sincronização NTP em todos os nós; auditar playbooks do SOAR para garantir que ações automatizadas de bloqueio não interrompam serviços de missão crítica.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'centralizes log collection and correlates events across heterogeneous devices'. Resposta: SIEM. 'Automates security response workflows and executes incident playbooks across multiple security tools' -> SOAR.

### 📌 WAF vs. NGFW: O Especialista em Navegador Web vs. O Guarda de Fronteira Geral

🏠 **Analogia Intuitiva:** O NGFW (Firewall de Nova Geração) é a alfândega do aeroporto internacional: ele confere passaportes, inspeciona se há armas e drogas em qualquer mala, sabe diferenciar um piloto de um turista e barra conexões maliciosas em qualquer porta ou protocolo. O WAF (Web Application Firewall) é o crítico de arte gastronômica que inspeciona exclusivamente os pratos do restaurante italiano da praça de alimentação: ele lê o molho de cada prato para garantir que ninguém colocou veneno ou pedras no macarrão (protege especificamente aplicações web contra SQL Injection e Cross-Site Scripting).

🔍 **Causa Raiz / Por que foi criado:** O NGFW protege o tráfego corporativo amplo (L3 a L7), mas não analisa profundamente os parâmetros complexos de formulários HTTP. O WAF é especializado nas ameaças do OWASP Top 10 que atacam diretamente a lógica e os bancos de dados de aplicações web.

🛡️ **Visão do Auditor de GRC:** Verificar se aplicações web expostas à Internet e que processam cartões de crédito possuem WAF obrigatório conforme exigido pelo PCI-DSS Requisito 6.6; certificar a ativação de inspeção SSL/TLS nos NGFWs.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'appliance placed in front of public web servers specifically designed to protect against SQL injection and Cross-Site Scripting (XSS)'. Resposta: Web Application Firewall (WAF).

### 📌 DLP de Rede (Data Loss Prevention): O Fiscal da Porta de Saída de Dados

🏠 **Analogia Intuitiva:** É o fiscal de saída da alfândega com aparelho de raio-X inspecionando cada caminhão e pacote que tenta cruzar a fronteira para o exterior: se ele enxergar formatos que se parecem com 16 dígitos de cartões de crédito, CPFs ou arquivos com marca d'água 'CONFIDENCIAL', ele bloqueia a carga na hora e aciona o alarme antes que o caminhão saia do país.

🔍 **Causa Raiz / Por que foi criado:** Exfiltração de dados confidenciais por funcionários mal-intencionados ou malwares enviando arquivos confidenciais por e-mail, uploads web ou conexões FTP não autorizadas.

🛡️ **Visão do Auditor de GRC:** Conferir a eficácia das regras de correspondência padrão (expressões regulares para números de cartões com algoritmo de Luhn e CPF); verificar se o Network DLP inspeciona tráfego criptografado através de quebra de SSL corporativa.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'prevents unauthorized exfiltration of sensitive proprietary data, credit card numbers, and PII across network egress points'. Resposta: Network DLP (Data Loss Prevention).

## ⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

| Cenário Típico de Exame / Situação Prática | Conceito Técnico & Resposta da Banca |
|---|---|
| Equipamento físico dedicado que gera e armazena chaves criptográficas com proteção contra violação física e autodestruição | **HSM (Hardware Security Module)** |
| Sistema centralizado de coleta, retenção, normalização e correlação em tempo real de logs de eventos de segurança | **SIEM (Security Information and Event Management)** |
| Plataforma que automatiza a triagem de incidentes e executa playbooks programados para bloquear ameaças sem ação humana | **SOAR (Security Orchestration, Automation, and Response)** |
| Dispositivo especializado em filtrar e bloquear ataques direcionados especificamente a aplicações web, como SQL Injection e XSS | **WAF (Web Application Firewall)** |
| Firewall avançado capaz de identificar aplicações independentemente da porta utilizada e realizar inspeção profunda de pacotes (DPI) | **NGFW (Next-Generation Firewall)** |
| Dispositivo de segurança que monitora o tráfego de saída da rede para impedir vazamento acidental ou roubo de dados confidenciais | **Network DLP (Data Loss Prevention)** |

## ✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

**QUESTÃO 1 · CENÁRIO DE EXAME**

**Um administrador de sistemas precisa fornecer acesso administrativo remoto seguro a uma rede de gerenciamento protegida que hospeda dispositivos de rede, hypervisors e controladoras de armazenamento. A equipe de segurança exige que nenhuma conexão administrativa direta de entrada seja permitida para esses ativos críticos a partir de fora da rede. Qual appliance de rede deve ser implantado como o ponto de entrada único e controlado para sessões administrativas nessa zona de gerenciamento isolada?**

**A)** Um reverse proxy configurado na DMZ para terminar TLS e encaminhar tráfego HTTPS administrativo para endpoints de gerenciamento

**B)** Um sensor IPS inline posicionado no perímetro de gerência executando inspeção profunda de pacotes e controle de conexões

**C)** Um jump server colocado em uma sub-rede protegida que intermedia todas as sessões administrativas autenticadas para a rede de gerência

**D)** Um load balancer configurado com distribuição de tráfego round-robin e monitoramento de integridade entre as controladoras

**QUESTÃO 2 · CENÁRIO DE EXAME**

**Uma empresa de médio porte deseja reduzir custos de largura de banda e aplicar políticas de uso aceitável para o tráfego web de saída de 800 funcionários. A equipe de segurança também precisa bloquear domínios maliciosos conhecidos e impedir que os usuários façam upload de documentos confidenciais para serviços de nuvem não autorizados. Qual appliance atende melhor aos três requisitos posicionando-se entre os usuários e a Internet?**

**A)** Um forward proxy que inspeciona requisições HTTP/HTTPS de saída, aplica filtragem de conteúdo e armazena em cache objetos frequentes

**B)** Um reverse proxy implantado na DMZ que termina sessões de clientes externos, exige autenticação e armazena respostas dos servidores

**C)** Um jump server reforçado configurado como gateway intermediário que autentica e gerencia o tráfego administrativo interno

**D)** Um sensor IDS passivo de rede colocado no perímetro que monitora o tráfego de saída e registra alertas de desvio de políticas

**QUESTÃO 3 · CENÁRIO DE EXAME**

**Uma empresa de comércio eletrônico hospeda um aplicativo de checkout voltado para o público em vários servidores web internos atrás de um único endereço IP público. O engenheiro de segurança deseja terminar o TLS em um appliance de perímetro, ocultar a topologia do servidor interno contra invasores e inspecionar requisições de entrada em busca de payloads maliciosos antes que cheguem aos servidores de aplicação. Qual appliance deve ser implantado na DMZ?**

**A)** Um forward proxy posicionado na borda de saída que aplica categorização de conteúdo externo e bloqueia uploads não autorizados

**B)** Um reverse proxy colocado na DMZ que termina HTTPS de entrada, oculta a topologia interna de IPs e inspeciona requisições de aplicação

**C)** Um jump server dedicado colocado em uma sub-rede administrativa que autentica administradores remotos e faz a ponte de sessões SSH

**D)** Um sensor IDS passivo conectado a uma porta SPAN de switch central que analisa fluxos de pacotes espelhados e gera alertas na DMZ

**QUESTÃO 4 · CENÁRIO DE EXAME**

**Um serviço de streaming está enfrentando tempos de resposta lentos nos horários de pico. A equipe de aplicação implantou seis servidores idênticos no data center, mas um health check revela que um servidor está retornando erros HTTP 503. O arquiteto de rede deseja remover automaticamente o servidor com falha do pool, distribuir novas conexões de clientes uniformemente entre os servidores íntegros e fornecer offloading de SSL. Qual appliance atende a esses requisitos?**

**A)** Um reverse proxy configurado com registro DNS estático round-robin que direciona sessões de usuários ao primeiro nó interno disponível

**B)** Um jump server reforçado configurado com túneis seguros que agrega requisições de streaming de entrada nos endpoints do cluster

**C)** Um sensor IPS inline posicionado no gateway que descarta respostas HTTP malformadas e reseta conexões para nós backend não saudáveis

**D)** Um load balancer que realiza health checks ativos, distribui tráfego entre nós backend íntegros e executa offloading de descriptografia TLS

**QUESTÃO 5 · CENÁRIO DE EXAME**

**Uma equipe de operações de segurança precisa de um dispositivo de rede que monitore o tráfego leste-oeste entre máquinas virtuais dentro do data center, copie pacotes para análise e gere alertas quando forem identificadas assinaturas de ataques conhecidos. O dispositivo NÃO DEVE modificar ou bloquear o tráfego porque a equipe quer apenas visibilidade para calibrar regras de detecção. Qual implantação atende melhor a esse requisito?**

**A)** Um sensor IDS passivo conectado a uma porta SPAN/mirror que analisa cópias do tráfego e gera alertas em correspondências de assinatura

**B)** Um sensor IPS inline implantado diretamente no fluxo de tráfego que avalia pacotes leste-oeste e encerra conexões suspeitas em tempo real

**C)** Um reverse proxy colocado à frente dos hypervisors virtuais que intercepta e inspeciona todas as comunicações entre máquinas virtuais

**D)** Um load balancer posicionado entre switches virtuais que distribui fluxos de tráfego espelhado entre appliances dedicados de inspeção

**QUESTÃO 6 · CENÁRIO DE EXAME**

**Após vários ataques bem-sucedidos de injeção de SQL passarem despercebidos pela detecção por assinatura, a equipe de segurança deseja um dispositivo inline à frente dos servidores web públicos que possa inspecionar corpos de requisições HTTP, descartar requisições maliciosas em tempo real e atualizar suas assinaturas automaticamente a partir do feed de ameaças do fornecedor. Qual appliance a equipe deve implantar?**

**A)** Um sensor IDS passivo conectado a uma porta mirror da DMZ que monitora requisições de entrada e grava alertas de intrusão no log

**B)** Um reverse proxy configurado com regras de cache que armazena requisições web e entrega conteúdo estático aos usuários externos

**C)** Um sensor IPS inline posicionado diretamente no caminho da rede que realiza inspeção profunda de pacotes e descarta requisições maliciosas

**D)** Um jump server reforçado configurado para autenticar conexões web de entrada antes de encaminhar consultas para o cluster de banco

**QUESTÃO 7 · CENÁRIO DE EXAME**

**Uma organização multinacional possui firewalls, switches, servidores e agentes de endpoint gerando milhões de entradas de log por dia em diferentes formatos e fusos horários. O SOC deseja um ponto de coleta único que normalize carimbos de data/hora e formatos, enriqueça eventos e os encaminhe para uma plataforma analítica central para correlação. Qual appliance cumpre melhor esse papel?**

**A)** Um sensor IPS inline implantado no switch central que descarta pacotes malformados e agrega alertas de conexão em armazenamento local

**B)** Um jump server reforçado na sub-rede de gerência que intermedia sessões administrativas e grava comandos executados em arquivos de texto

**C)** Um reverse proxy configurado no perímetro de rede que termina sessões criptografadas de clientes e grava cabeçalhos HTTP em disco central

**D)** Um coletor de logs que ingere dados de diversas fontes, normaliza esquemas de eventos e encaminha lotes com segurança para o SIEM corporativo

**QUESTÃO 8 · CENÁRIO DE EXAME**

**Um analista de SOC deseja consultar uma plataforma centralizada que combina logs de firewall, logs de eventos do Windows, alertas de IDS, logs de proxy web e eventos de autenticação em um único painel. A plataforma deve suportar regras de correlação que combinem eventos dessas diferentes fontes para detectar ataques em múltiplos estágios, como phishing levando a movimento lateral. Qual solução atende melhor a esse requisito?**

**A)** Um jump server standalone configurado com scripts automatizados que periodicamente ingere arquivos de texto em um diretório local

**B)** Um SIEM que ingere eventos normalizados de múltiplos coletores, executa regras de correlação entre fontes e dispara alertas unificados

**C)** Um sensor IPS inline que agrega assinaturas de ataque de múltiplos fornecedores e bloqueia pacotes maliciosos na velocidade da rede

**D)** Um cluster de reverse proxies que consolida logs de acesso de servidores web e instâncias de banco de dados em um dashboard de relatórios

**QUESTÃO 9 · CENÁRIO DE EXAME**

**Uma pequena empresa financeira possui 12 servidores, vários switches e dois firewalls espalhados por um data center e uma filial. O CISO quer uma forma simples e segura para que os administradores realizem a manutenção de rotina em todos os dispositivos sem expor o SSH ou o RDP diretamente à Internet. A solução também deve produzir um log de auditoria único de quem fez o que e quando em todas as ações administrativas. Qual design atende melhor a essas metas?**

**A)** Implantar um jump server reforçado na VLAN de gerência, exigir que todos os admins se autentiquem nele primeiro e enviar logs para o SIEM

**B)** Abrir a porta TCP 22 nos firewalls de perímetro com políticas de senha restritivas, allowlists de IP e chaves locais nos laptops dos admins

**C)** Substituir os firewalls existentes por sensores IDS passivos que capturam cabeçalhos de pacotes e registram tentativas de acesso administrativo

**D)** Implantar um reverse proxy público sem autenticação que expõe painéis de administração web internos e portas de desktop remoto na Internet

**QUESTÃO 10 · CENÁRIO DE EXAME**

**Um arquiteto corporativo está projetando o perímetro de um novo data center e deve decidir onde posicionar vários appliances. Clientes internos navegarão na Internet, usuários públicos acessarão um cluster de servidores web, o SOC precisa de visibilidade de tráfego malicioso e administradores devem acessar todos os dispositivos internos com segurança. Qual alocação corresponde corretamente cada appliance à sua função?**

**A)** Reverse proxy para navegação de saída, forward proxy para tráfego web de entrada, jump server para inspeção e IDS para acesso de gerência

**B)** Jump server na DMZ para tráfego público, forward proxy para sessões administrativas, IDS terminando TLS e reverse proxy como gateway padrão

**C)** Sensor IDS fazendo cache de conteúdo web de saída, forward proxy inspecionando HTTPS, jump server bloqueando SQLi e reverse proxy para admins

**D)** Forward proxy para saída de clientes, reverse proxy na DMZ para tráfego web, sensor IDS/IPS no perímetro e jump server para acesso de gerência

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

**Questão 1: Alternativa C — Um jump server colocado em uma sub-rede protegida que intermedia todas as sessões administrativas autenticadas para a rede de gerência**

A resposta correta é C: Um jump server colocado em uma sub-rede protegida. O jump server (bastion host) atua como o ponto de entrada único, controlado e auditado para acesso administrativo a uma zona de gerenciamento isolada. Ele elimina conexões administrativas diretas (RDP/SSH) aos ativos críticos, reduzindo drasticamente a superfície de ataque. O reverse proxy (A) atende aplicações web e não protocolos administrativos gerais; o sensor IPS (B) inspeciona e bloqueia tráfego malicioso, mas não intermedia sessões de gerência; o load balancer (D) distribui cargas de trabalho e não isola o acesso de administração.

**Questão 2: Alternativa A — Um forward proxy que inspeciona requisições HTTP/HTTPS de saída, aplica filtragem de conteúdo e armazena em cache objetos frequentes**

A resposta correta é A: Um forward proxy. O forward proxy atua em nome dos clientes internos que fazem requisições de saída para a Internet. Ele atende perfeitamente aos três requisitos: reduz largura de banda armazenando objetos web em cache, aplica filtros de uso aceitável e inspeciona o tráfego de saída para bloquear domínios maliciosos e vazamento de dados. O reverse proxy (B) protege servidores internos contra clientes externos; o jump server (C) intermedia sessões administrativas; o IDS passivo (D) apenas monitora e alerta, sem filtrar ou fazer cache de tráfego de saída.

**Questão 3: Alternativa B — Um reverse proxy colocado na DMZ que termina HTTPS de entrada, oculta a topologia interna de IPs e inspeciona requisições de aplicação**

A resposta correta é B: Um reverse proxy colocado na DMZ. O reverse proxy fica à frente dos servidores web internos, terminando conexões TLS de entrada, ocultando endereços IP e a topologia de servidores backend, além de inspecionar requisições HTTP antes de repassá-las aos servidores internos. O forward proxy (A) atua no tráfego de saída de clientes internos; o jump server (C) provê acesso administrativo a hosts internos; o IDS passivo (D) apenas observa tráfego espelhado, incapaz de terminar TLS ou intermediar requisições em trânsito.

**Questão 4: Alternativa D — Um load balancer que realiza health checks ativos, distribui tráfego entre nós backend íntegros e executa offloading de descriptografia TLS**

A resposta correta é D: Um load balancer. Os load balancers monitoram ativamente a saúde dos nós backend, removem instâncias com falha (como HTTP 503) do pool de servidores, distribuem tráfego entre os servidores íntegros (via round-robin, least connections, etc.) e realizam o offload da descriptografia TLS para liberar processamento dos servidores. O reverse proxy básico (A) não faz gestão dinâmica de pool; o jump server (B) intermedia acesso administrativo; o IPS (C) detecta ameaças, não distribui cargas de aplicação.

**Questão 5: Alternativa A — Um sensor IDS passivo conectado a uma porta SPAN/mirror que analisa cópias do tráfego e gera alertas em correspondências de assinatura**

A resposta correta é A: Um sensor IDS passivo conectado a uma porta SPAN/mirror. Um Sistema de Detecção de Intrusão (IDS) opera out-of-band de forma passiva, recebendo cópias de pacotes (via porta SPAN ou TAP de rede) para detectar e alertar sobre atividades suspeitas sem interferir no fluxo de produção. Como o requisito proíbe expressamente modificar ou bloquear tráfego, o IPS inline (B) é descartado. Reverse proxies (C) e load balancers (D) não são dispositivos de detecção baseada em assinaturas.

**Questão 6: Alternativa C — Um sensor IPS inline posicionado diretamente no caminho da rede que realiza inspeção profunda de pacotes e descarta requisições maliciosas**

A resposta correta é C: Um sensor IPS inline posicionado diretamente no caminho da rede. Um Sistema de Prevenção de Intrusão (IPS) fica posicionado em linha com o fluxo de tráfego, permitindo inspecionar o conteúdo profundo dos pacotes e bloquear ou descartar ativamente requisições maliciosas em tempo real. O IDS passivo (A) apenas alerta, não bloqueia; o reverse proxy padrão (B) faz terminação e cache mas não tem feeds de descarte automático de exploits; o jump server (D) é para acesso administrativo, inadequado para clientes públicos da web.

**Questão 7: Alternativa D — Um coletor de logs que ingere dados de diversas fontes, normaliza esquemas de eventos e encaminha lotes com segurança para o SIEM corporativo**

A resposta correta é D: Um coletor de logs. O coletor de logs (ou forwarder/agregador) foi projetado especificamente para receber eventos de múltiplos dispositivos heterogêneos, normalizar diferentes formatos e fusos horários em um esquema comum e encaminhar os dados tratados para a plataforma central do SIEM. O sensor IPS (A) gera apenas seus próprios alertas; o jump server (B) grava apenas atividades das sessões administrativas que intermedia; o reverse proxy (C) gera logs de requisições web, mas não ingere nem normaliza logs de switches ou firewalls.

**Questão 8: Alternativa B — Um SIEM que ingere eventos normalizados de múltiplos coletores, executa regras de correlação entre fontes e dispara alertas unificados**

A resposta correta é B: Um SIEM (Security Information and Event Management). O SIEM recebe logs normalizados de diversos coletores, aplica regras de correlação entre fontes heterogêneas (ex: cruzar um log de phishing com a execução de um processo no endpoint e uma conexão no firewall) e disponibiliza dashboards e alertas consolidados. O jump server (A) apenas intermedia sessões de administração; o sensor IPS (C) atua bloqueando tráfego malicioso; o cluster de reverse proxy (D) cuida apenas do tráfego web.

**Questão 9: Alternativa A — Implantar um jump server reforçado na VLAN de gerência, exigir que todos os admins se autentiquem nele primeiro e enviar logs para o SIEM**

A resposta correta é A: Implantar um jump server reforçado na VLAN de gerenciamento. O jump server atua como um intermediário seguro e isolado para sessões administrativas, garantindo que portas como SSH (TCP 22) e RDP (TCP 3389) nunca fiquem expostas diretamente à Internet pública, enquanto centraliza a gravação e a auditoria de sessões. Abrir a porta SSH no perímetro (B) aumenta a superfície de ataque e expõe a ataques de força bruta; substituir firewalls por IDS passivo (C) elimina o bloqueio de tráfego; usar reverse proxy sem autenticação (D) cria uma vulnerabilidade crítica.

**Questão 10: Alternativa D — Forward proxy para saída de clientes, reverse proxy na DMZ para tráfego web, sensor IDS/IPS no perímetro e jump server para acesso de gerência**

A resposta correta é D: Forward proxy para saída de clientes, reverse proxy na DMZ para tráfego web, sensor IDS/IPS no perímetro e jump server para acesso de gerência. Cada appliance cumpre sua função arquitetural canônica: forward proxies gerenciam e armazenam em cache o tráfego de saída dos usuários internos; reverse proxies ficam na DMZ à frente dos servidores web; sensores IDS/IPS inspecionam o tráfego de perímetro; e jump servers intermedeiam o acesso administrativo de forma isolada e segura. As opções A, B e C trocam indevidamente as funções de cada appliance.